Comprehensive Examination Compliance & Traceability Report

Course Code: 20CYS401 — Secure Software Engineering
Degree: B.Tech CSE — Cybersecurity
Examination System: Online Book Review and Recommendation Platform
Date: October 2026

1. Executive Summary

This report documents the completed, verified implementation and documentation of the **Online Book Review and Recommendation Platform** developed in fulfillment of the **20CYS401 Secure Software Engineering** examination requirements.

Every phase has been implemented through real working software, verified through automated tests and security scanners, and accompanied by formal engineering artifacts.

2. Examination Phase Compliance Matrix

Phase	Phase Title	Status	Primary Artifacts	Verification Evidence
Phase 0	Workspace & Environment Setup	COMPLETE	`PROJECT_STATUS.md`, `requirements.txt`, `.gitignore`	Scaffolding created, git repo initialized
Phase 1	Agile Process & XP Security	COMPLETE	`docs/phase-01-agile/agile-approach.md`	5 Agile principles mapped, 2 refactorings documented
Phase 2	Requirements Engineering (SRS)	COMPLETE	`docs/phase-02-requirements/srs.md`	REQ-01 through REQ-12 specified with acceptance criteria
Phase 3	UML Use Case Modeling	COMPLETE	`docs/phase-03-uml/use-cases.md`	Mermaid use case diagram, UC-01 & UC-02 specs, scenario trace
Phase 4	Data Flow & Trust Boundaries	COMPLETE	`docs/phase-04-data-flow/er-dfd-trust-boundaries.md`	Mermaid ER diagram, Level-0/1 DFDs, Trust Boundary model
Phase 5	Software Architecture	COMPLETE	`docs/phase-05-architecture/architecture.md`	4-layer architecture, component inventory (COMP-01..08)
Phase 6	UI & User Workflows	COMPLETE	`docs/phase-06-ui/ui-screens.md`	6 connected server-rendered screens in `app/templates/`
Phase 7	Threat Modeling (STRIDE)	COMPLETE	`docs/phase-07-threat-model/stride-analysis.md`	10 assets (ASSET-01..10), 10 threats (THR-01..10) mapped
Phase 8	Attack Tree Analysis	COMPLETE	`docs/phase-08-attack-tree/attack-tree.md`	ATK-01 Mermaid AND/OR tree for review tampering
Phase 9	Product Backlog & Stories	COMPLETE	`docs/phase-09-backlog/user-stories.md`, `jira-import.csv`	10 user stories (US-01..10), story points, Jira CSV
Phase 10	Sprint Metrics & Burndown	COMPLETE	`docs/phase-10-sprint/sprint-metrics.md`	Sprint velocity table, Mermaid burndown chart
Phase 11	Secure Build & SAST Scans	COMPLETE	`evidence/phase-11/bandit_scan.txt`, `secret_scan_report.txt`	Bandit scan (0 High, 0 Med), Secret scan verified

Phase	Phase Title	Status	Primary Artifacts	Verification Evidence
Phase 12	Secure Coding & IDOR Demo	COMPLETE	`docs/phase-12-secure-coding/idor-demonstration.md`	Exploit proved on `demo/idor-before`, mitigated on `main`
Phase 13	Containerization	COMPLETE	`docker/Dockerfile`, `docker-compose.yml`, `.dockerignore`	Multi-stage build, unprivileged user UID 10001, health probe
Phase 14	Testing & Verification	COMPLETE	`tests/`, `evidence/phase-14/pytest_output.txt`	23/23 tests passing (unit, auth, integration, fuzzing, e2e)
Phase 15	Logging & Monitoring	COMPLETE	`docs/phase-15-monitoring/monitoring.md`, `app/core/audit.py`	AuditLog model, secret scrubbing, `/health` endpoint
Phase 16	Hardening & Review	COMPLETE	`docs/phase-16-hardening/security-review.md`, `SECURITY.md`	10 security controls implemented and verified

3. End-to-End Traceability Sample

```
REQ-07 (Edit Own Review)
  |
  ▼
UC-01 (Submit/Edit/Delete Review)
  |
  ▼
DFD-P04 (Review Processing Process)
  |
  ▼
THR-02 (STRIDE Tampering Threat: Review Modification via IDOR)
  |
  ▼
ATK-01 (Attack Tree: Path 1 IDOR Exploitation)
  |
  ▼
VUL-01 (Insecure Direct Object Reference)
  |
  ▼
US-05 (User Story: Edit & Delete Own Reviews)
  |
  ▼
CTRL-02 (Object-Level Authorization Check in ReviewService)
  |
  ▼
TEST-05 (test_user_b_cannot_edit_user_a_review)
  |
  ▼
RESULT: PASSED (evidence/phase-12/idor_fix_verification.txt)
```

4. Conclusion

All 16 examination phases for Course Code **20CYS401** have been completely fulfilled. The platform is secure, runnable locally, verified through automated test suites and SAST scans, containerized for production deployment, and thoroughly documented.